



SEGURANÇA

Project 04 (A+B)	A: Deadline (01-11): 2025/04/23 (13:00) B: Deadline (12-22): 2024/04/30 (13:00)	2026/04/09
Expected time: 240 minutes	Contact and Non-contact hours	Using lab resources
Name: _____	N.: _____	Total.: _____

Este projeto deve ser realizado até à data acima mencionada (deadline). Deve fazer um relatório resumido para cada deadline, com screenshots e texto que os enquadre, que evidencie e contextualize a sua realização. Deve usar a mesma numeração de perguntas e identificação das alíneas das perguntas para as respostas. Anote na capa do relatório o nome da unidade curricular (Segurança), o ano letivo (2025/2026) o seu nome completo, email, número de aluno, data de entrega e o tempo que demorou a realizar o projeto. Dentro de uma pasta "Project04A"/"Project04B" (1º/2º deadline) coloque o relatório em PDF assim como os ficheiros das capturas de tráfego relevantes. O nome de cada ficheiro de captura de tráfego deve começar pelo número e alínea da pergunta em causa (ex. 6-RADIUS.pcap). Comprima em formato zip a pasta com todos os ficheiros e entregue o arquivo na respetiva atividade do Nónio. O projeto poderá ainda ser avaliado em aula por teste e/ou inspeção (topologia funcional e/ou capturas de tráfego). Expressões neste enunciado a azul e sublinhadas representam ligações a recursos externos. Leia o enunciado até ao final antes de iniciar a realização do projeto. Reserve um período um pouco maior que o tempo previsto para realização do projeto sem interrupções. Faça pausas e caminhe a cada 40 minutos.

Tenha em atenção os seguintes requisitos prévios:

- O enunciado é extenso por incluir explicações e instruções detalhadas que o ajudarão a poupar tempo e compreender melhor os conceitos abordados. A maior parte dos pontos fazem-se num minuto ou menos. Existem alguns pontos que propositadamente desafiam a sua capacidade de estudo autónomo. Obviamente exigem muito mais tempo que os restantes pontos pois requerem alguma pesquisa e algum trabalho de tentativa e erro. Não estará a perder tempo. Estará a investi-lo no treino de uma das competências que mais lhe será útil no futuro: a sua autonomia / capacidade autodidata. O enunciado está redigido para tomar contacto com mais assuntos do que a Cisco aborda no CCNA Security. Isso vai-lhe ser útil no futuro. Tenha uma postura competitiva perante estes desafios. Você afinal ambiciona ser engenheiro e não um mero técnico. Você ambiciona compreender como a tecnologia funciona. Só isso lhe permitirá progredir e vir a criar soluções que ultrapassem as limitações das atuais. Evite solicitar qualquer ajuda (numa primeira fase) aos seus colegas. Só assim estará de facto a treinar competências que lhe serão fundamentais. Os resultados iniciais demorarão muito. Não desanime. É agora a altura certa para o ritmo lento acontecer. Aos poucos você ficará cada vez mais ágil.
 - É recomendado que leia o enunciado todo antes de iniciar a sua resolução. Antes de iniciar a resposta a cada ponto releia-o por completo e releia o ponto seguinte. Comece este projeto apenas se dispõe de duas ou três horas seguidas livres. Será mais rentável assim para não perder a cadeia de raciocínio. Faça pausas de 15 minutos a cada 45 minutos de trabalho.
 - A sequência de exercícios e passos solicitada tem de ser rigorosamente seguida. Vá guardando um histórico da configuração exata dos equipamentos no início de cada exercício. Deste modo poderá fazer pausas e retomar mais tarde a realização do projeto sem prejuízo do resultado final. Basta que aplique essa configuração. Vá guardando cópias da configuração do router.
 - Comece por clonar a topologia usada no Projeto 03.
 - Estude os módulos 6 e 7 do currículo [CCNA Network Security](#). Pode encontrar informação mais detalhada no *site* da Cisco, nomeadamente no [User Security Configuration Guide, Cisco IOS Release 15MT](#).
 - Considere ainda a apresentação "Authentication, Authorization, and Accounting" partilhada na plataforma Nónio e abordada nas aulas.
1. Ligue ao *switch* da rede A (SWA) uma instância da [AAA GNS3 appliance](#) (denominada doravante AAA-1). Siga, para esta instância, as mesmas regras que foram enunciadas no primeiro projeto para endereçar a nível 3 (endereço IP) e 2 (endereço MAC) os terminais da rede. Tenha em consideração que este será o seu quarto terminal da rede A. Corra o comando `ifconfig` de modo a comprovar o correto endereçamento deste novo servidor. Faça um *screenshot* do comando e respetivo *output* produzido. Clicando com o botão direito sobre AAA-1 selecione a opção *Configure* e em seguida

consulte o conteúdo do separador `Usage` das `Node properties` para conhecer algumas configurações presentes por omissão nesta *appliance*.

2. Abra uma consola em AAA-1 e execute o comando que lhe permita ver os `sockets` UDP ativos com a indicação de que o porto de escuta é `radius / radius-acct`. Corra o mesmo comando mas parametrizado de forma a que surjam os números dos portos em causa (vai precisar dessa informação adiante) e não os nomes dos serviços associados. Faça um único *screenshot* dos comandos e respetivo *output* produzido. Nos enunciados anteriores encontra os comandos a usar.
3. Para descobrir o software que está a fornecer o serviço RADIUS (*Remote Authentication Dial In User Service*), e desse modo investigar como o pode configurar (pretende criar um novo utilizador para além dos existentes – “alice” e “bob” – e dar-lhe uma senha escolhida por si), corra no terminal AAA-1 o comando `service --status-all`. Por vezes a instalação e configuração do mesmo software / serviço varia de sistema operativo para sistema operativo. Consulte o *flavor* Linux em causa (comum a todos os terminais da topologia pois são *containers* alojados na VM onde corre o próprio servidor GNS3): `uname -a`. Faça um único *screenshot* dos comandos e respetivo *output* produzido. Pesquise agora ([Google](#)) manuais *online* de apoio à configuração do serviço RADIUS (*Remote Authentication Dial In User Service*) que se encontra ativo no terminal AAA-1 no âmbito do sistema operativo em apreço. Nota: Quando se conhece o paradigma (mais ou menos semelhante) de configuração de serviços em Linux, uma forma mais rápida de descobrir como se configura um serviço específico passa por procurar as propriedades da conta criada para a sua instalação. Uma inspeção atenta à base de dados de utilizadores pode ajudar: `cat /etc/passwd`. Repare na última linha deste ficheiro e atente particularmente na *home directory* do utilizador aí registado. Liste o conteúdo de tal pasta. Inspeccione as diretorias e localize o ficheiro que (suspeite) é usado para alojar as contas dos utilizadores autenticados pelo RADIUS. Leia resumidamente a totalidade do mesmo. Estude num dos *links* devolvidos na pesquisa que fez como deve proceder para adicionar utilizadores a esta base de dados (se não encontrou nenhuma fonte de informação esclarecedora use [esta](#)). Pretende-se que adicione (recorrendo ao editor `pico`, por exemplo) um novo utilizador (a esse ficheiro) cujo *username* seja igual à primeira letra do seu primeiro nome, concatenada com o seu último apelido (sem espaços, acentos ou caracteres especiais) (ex. `lsantos`). Defina uma *password* diferente da que os restantes utilizadores registados possuem. Defina também uma nova *Reply-Message*, mais personalizada. Mostre em *screenshot* a configuração que acrescentou ao respetivo ficheiro.
4. Para além de um novo utilizador pretende-se que registe na configuração do servidor RADIUS o *router* R1 como seu cliente. Se inspecionar a pasta onde está a base de dados de utilizadores (ou o *link* simbólico para a mesma) também encontrará um ficheiro `clients.conf` que constitui a base de dados destes clientes. Edite esse ficheiro com a ferramenta `pico`. Crie uma nova entrada no final do ficheiro que identifique o cliente (o *router* R1) pelo seu IP. Associe-lhe uma senha distinta do valor por omissão (“gns3”). Mostre em *screenshot* a configuração que acrescentou ao respetivo ficheiro depois de completamente validada (processo que apenas se completará após resolver com sucesso os próximos exercícios: não esqueça por isso de regressar a este ponto mais tarde para realizar o *screenshot* com a configuração já validada).
5. Nos próximos exercícios é importante socorrer-se da informação de depuração do IOS para compreender como R1 gere todos os processos AAA. Se estiver ligado por consola deve correr os seguintes comandos (`debug aaa authentication`, `debug aaa authorization`, `debug aaa accounting`). Se pretender acompanhar os processos numa sessão SSH, além destes comandos deve ainda correr o comando `terminal monitor` para que as mensagens de *debug* e outros *logs* lhe sejam entregues.
6. Configure R1 como cliente do serviço RADIUS alojado em AAA-1 para efeitos de autenticação quer de sessões SSH quer de acessos pela consola que sejam solicitados ao *router*. De acordo com a terminologia RADIUS, no cenário em estudo, R1 é considerado um *Network Access Server* (NAS). Esta denominação tem raízes histórias. Nos primórdios da sua utilização, este protocolo (desenvolvido pela Livingston Enterprises) era usado para centralizar a autenticação dos clientes dos ISPs nos seu *Points-Of-Presence* (POPs), a partir dos quais obtinham acesso à Internet. Deve programar a lista `default` apenas. Esta lista deve possuir o método RADIUS seguido do método `local` (nesta sequência). Antes de avançar crie em R1 um utilizador local cujo nome seja constituído pelo seu primeiro nome e a primeira letra do seu último nome (ex. `luiss`). Não lhe associe nenhum nível de privilégios ou vista.

Adicione na linha de consola (line con 0) a seguinte configuração: `privilege level 15`. Este comando sobrepor-se-á, para efeitos de autorização, a qualquer outra “ordem” independentemente da sua proveniência. Confirme que as linhas `vty` não possuem este comando. Assim configurada, esta conta será a sua *local fallback account*. O objetivo da mesma é permitir-lhe realizar acessos por consola com privilégios máximos para poder configurar o *router* mesmo quando o servidor RADIUS estiver indisponível. Ainda que no GNS3 possa editar a configuração do *router* pela interface gráfica (opção `Edit config` à qual acede clicando com o botão direito do rato sobre o nó) é importante não esquecer que numa rede real pode realmente perder acesso aos canais de configuração do *router* se a autenticação só for assegurada por serviços externos, como o RADIUS, e estes estejam indisponíveis. Inicie no GNS3 uma captura de tráfego sobre a interface que R1 usará para comunicar com AAA-1. Por fim teste a configuração realizada. Pode fazê-lo diretamente em R1 através do comando `test aaa group radius lsantos passwordDeLsantos legacy`. Para já a autenticação deve falhar. Guarde *screenshots* com a configuração acrescentada em R1, o resumo das duas PDUs RADIUS capturadas na sequência do teste mencionado e o resultado reportado pelo comando `test`. Repita a verificação a partir de A1: `ssh lsantos@EndereçoIP_R1`.

7. Os serviços Linux normalmente precisam de ser notificados de alterações feitas pelo administrador nos seus ficheiros de configuração de modo a relerem os mesmos. Para que tudo funcione de acordo com a configuração realizada até aqui esse, provavelmente, é o único passo que lhe resta fazer. Temos que alertar o serviço RADIUS para reler as bases de dados de utilizadores e de clientes que você alterou. Este tipo de notificação dos serviços em Linux normalmente é feito enviando um sinal ao processo (usando o comando `kill`). Normalmente é usado o sinal `SIGHUP`. Tal implica saber o PID do processo. É por isso que os serviços normalmente ao arrancarem escrevem o seu PID num ficheiro de nome e localização definidos na sua documentação (`cat /var/run/freeradius/freeradius.pid`). Para simplificar todos estes procedimentos, comuns a todos os serviços Linux, existe uma abordagem padrão (respeitada também pelo [FreeRADIUS](#)) que permite recorrer à ferramenta [service](#) e a um conjunto de *shell scripts* desenvolvidos para cada serviço e que esta ferramenta invoca. O modo de configuração de todos os serviços tende a ser uniforme o que simplifica o trabalho de administração. Para que o serviço de RADIUS releia todos os ficheiros alterados execute o comando `service freeradius reload`. Se ler a *manpage* do comando `service` percebe que o primeiro argumento (`freeradius`) é o nome de um *script*. Onde estará o *script* `freeradius`? Pela documentação da referida *manpage* é fácil de descobrir (`/etc/init.d/`). Inspeccione (recorrendo ao editor `pico`, por exemplo) este ficheiro, localize e transcreva a parte do *script* relativa ao segundo argumento (`reload`) do *script* `service`. Descubra, analisando este mesmo *script*, o argumento do comando `service` que deve usar para consultar o estado do serviço. Consulte o respetivo estado. Por vezes apenas o `reload` dos serviços não é suficiente. Pode mesmo ter que parar e reiniciar o serviço: `service freeradius stop` seguido de `service freeradius start` (ou, de forma equivalente mas mais rápida, apenas `service freeradius restart`). Inspeccione as capturas de PDUs RADIUS e proceda ao devido *troubleshooting* até a autenticação de sessões SSH com as credenciais do novo utilizador que criou ficar operacional. Deve ter o cuidado de guardar a captura pois vai precisar dela na avaliação. Pode ser útil ativar os eventos de *logging* para ficarem registados todos os eventos de autenticação do serviço RADIUS afinando as definições de configuração (`pico /etc/freeradius/3.0/radiusd.conf`). Se pretender vigiar os eventos reportados corra o comando `tail -f /var/log/freeradius/radius.log`. Faça o *screenshot* dos comandos experimentados e dos detalhes das PDUs RADIUS `Access-Request` e `Access-Accept` de modo a ser visível o `username` e a `Reply-Message` respetivamente. Investigue ([RFC 2865](#)) como é ofuscada a `password` do utilizador quando R1 solicita a AAA-1 a validação das credenciais. Faça um resumo de 4 linhas do processo. Em que livro se inspiraram os autores da RFC para este efeito? Analise cautelosamente as capturas e faça um diagrama que permita compreender a sequência temporal de mensagens trocadas entre os sistemas envolvidos e os eventos relevantes que decorrem desde que um utilizador corre o comando `ssh` num terminal externo até receber o *prompt* de R1.
8. Anote, com ajuda do Wireshark, o conteúdo do campo `Authenticator` da PDU RADIUS `Request` capturada (guarde as capturas para mostrar durante a avaliação). Estude (ex. [RFC 2865](#)) como se calcula este campo (dê especial atenção à secção 7 da RFC). Com ajuda dos exemplos fornecidos, e seguindo as especificações, calcule o valor deste campo no caso concreto da PDU que capturou.

Guarde os sucessivos passos deste cálculo. O Wireshark permite copiar para a *clipboard* o valor de qualquer campo em vários formatos (binário, hexadecimal, etc.). Guarde os passos envolvidos no cálculo com os seus valores em concreto. Use uma calculadora online (ex.: [cryptii](#)). Conseguiu chegar ao mesmo valor? Para que serve este campo (i.e., que serviços de segurança oferece)? Explique como a sua forma de cálculo permite alcançar o seu desígnio.

9. Assim que for bem-sucedido a abrir uma sessão SSH para R1 a partir de A1 execute o comando `show privilege`. Em que nível de privilégios se encontra? Mostre um *screenshot* do comando acompanhado do respetivo *output*. Consegue aceder a outro nível de privilégios (`enable`)? Consegue entrar no modo de configuração? Que configuração terá determinado esse nível de privilégios? Inspeção com atenção as PDUs RADIUS (na captura *wireshark* aplique o filtro de visualização `radius`). Depois de um cabeçalho inicial cada item da informação trocada (`username`, `password`, etc.), tanto no pedido como na resposta, é transportado numa lista de pares atributo-valor (também denominados *Av Pairs: Attribute-Value Pairs*). A estrutura de cada atributo-valor é composta por três campos, conhecidos na gíria protocolar por TLV. Trata-se de uma abordagem usada pelo IETF em muitos protocolos. Cada par é caracterizado por tipo (*Type*), tamanho (*Length*) – em bytes e valor (*Value*). Encontra um dicionário dos *Av Pairs* suportados pela Cisco [aqui](#). Anote os pares atributo-valor se encontram no pedido (`Access-Request`) e na resposta (`Access-Accept`) RADIUS capturadas.
10. Entre pela consola em R1 (para ficar com o nível máximo de privilégios) e, em modo de configuração, adicione às linhas VTY (`line vty 0 4`) a seguinte configuração `privilege level 15` (este comando sobrepor-se-á a qualquer outra “ordem” de autorização). O nível de privilégios mencionado será atribuído a qualquer utilizador que se autenticar corretamente por estas linhas. Termine a sessão SSH que estabeleceu com R1 e volte a estabelecê-la. Em que nível de privilégio se encontra? Mostre um *screenshot* do comando acompanhado do respetivo *output*. Retire o último comando introduzido nas linhas VTY. Grave a configuração.
11. Quando cria uma conta de um novo utilizador no IOS (base de dados `local`) é possível associar um nível de privilégios (`username luiss privilege 15 secret XPTO`) ou até uma vista (`username luiss view MASTER secret XPTO`). Ao fazê-lo está na verdade a instruir o IOS para pôr em marcha de imediato o processo de autorização individual (se a autenticação for bem-sucedida). É possível com o protocolo RADIUS fazer o mesmo: fornecer autorização durante o processo de autenticação. A Cisco esclarece: “*Because RADIUS user authorization information is piggybacked in authentication responses, the authentication and authorization methods must use the same RADIUS scheme.*”. Para realizar autorização via RADIUS é necessário completar duas tarefas: a) alertar o *router* que deve estar “atento” à informação de autorização que o RADIUS remeter; b) associar à conta de cada utilizador registado no RADIUS a informação de autorização pretendida. Na primeira das tarefas mencionadas estamos a solicitar ao servidor RADIUS que adicione à lista devolvida na reposta `Access-Accept` alguns *AV Pairs* com a informação necessária. Para fazer esta solicitação ao servidor RADIUS deve adicionar à informação da conta de cada utilizador (`/etc/freeradius/3.0/users`) as duas últimas linhas da configuração mencionada de seguida (`Service-Type` e `Cisco-AVPair`):

```
lsantos Cleartext-Password := "12#$56/("
Reply-Message = "Ola %{User-Name}, seja bem-vindo!",
Service-Type = NAS-Prompt-User,
Cisco-AVPair = "shell:priv-lvl=15"
```

Após gravar o ficheiro com os atributos atualizados não esqueça de instruir o serviço RADIUS para o reler: `service freeradius reload` (ou `service freeradius restart` se necessário).

O IETF, além de prever vários pares *standard*, previu um, denominado vendor-specific, que os fabricantes (como a Cisco) podem explorar para transportar atributos proprietários, denominados *Vendor-Specific Attributes* (VSA). Repare que conceitos como privilégios ou vistas são específicos da Cisco. Outros fabricantes usarão porventura outras abordagens para lidar com permissões. No IOS, para realizar a segunda tarefa atrás mencionada (b), é suficiente integrar na lista de métodos de autorização o RADIUS. Tal como na autenticação, podemos criar uma lista específica de métodos de autorização ou configurar simplesmente a lista *default*. Use esta última abordagem (o que lhe evita uma linha de configuração adicional sobre as linhas VTY). Através da consola de R1 (para possuir o nível máximo de privilégios) e, em modo de configuração, execute o comando `aaa authorization exec`

`default group radius`. Com isto estará a indicar que, se corretamente autenticado, um utilizador também deverá ser autorizado via RADIUS. Ao fazê-lo R1 irá procurar, na mensagem de `Access-Accept` que recebe do serviço RADIUS, pares atributo-valor destinados a este efeito. Repare que o processo de autorização tem de ser articulado entre o cliente RADIUS (R1) e o serviço RADIUS (AAA-1). Sem a correta sintonia a autorização por esta via não é realizada. Trata-se de uma prudência de segurança nível de *design*. Guarde a captura em curso e inicie outra. Termine a sessão SSH que estabeleceu com R1. Volte a estabelecê-la. Inspeção o tráfego RADIUS. Analise a lista de AV Pairs no pedido e na resposta. Compare-a com a lista que tinha anotado antes da autorização ser feita por RADIUS. Guarde um *screenshot* da mensagem `Access-Accept` onde sejam visíveis os detalhes dos AV Pairs incluídos. Releia a [documentação](#) e explique a semântica associada aos novos pares presentes na resposta. Reveja a configuração que fez na conta do utilizador que registou no RADIUS e estabeleça a correspondência entre cada nova linha adicionada e cada novo par atributo-valor presente na resposta do RADIUS. Tire conclusões. Qual é o *Vendor ID* da Cisco para efeitos de VSAs RADIUS? Que entidade, na regulação da Internet, é responsável por atribuir estes IDs? Onde pode encontrar uma lista atualizada com os IDs atribuídos por essa entidade? Que nível de privilégios detêm o utilizador depois de autenticado na sessão SSH?

12. Anote os resultados de cada uma das seguintes experiências (solicitadas neste e nos pontos seguintes) precedidos da configuração relevante do *router* usada durante a mesma. Será essa configuração que determinará o resultado de cada experiência. Neste e nos próximos pontos vai estudar do cenário de *fallback* no qual o serviço RADIUS não está disponível. Para emular esta situação comece por parar o serviço RADIUS (`service freeradius stop`). Termine as sessões estabelecidas com R1 (SSH e consola). Restabeleça as sessões por SSH e consola com R1 usando o utilizador registado no RADIUS (ex. `lsantos`). O que sucedeu? Teve de esperar? Conseguiu entrar? Justifique os comportamentos observados.
13. Tente agora restabelecer apenas a sessão por consola com R1 usando as credenciais do utilizador criado em R1 (`luiss`). O que sucedeu? Teve de esperar? Conseguiu entrar? Que privilégios obteve? Justifique os comportamentos observados.
14. Com a sessão de consola estabelecida tente de novo entrar por SSH com as credenciais registadas no servidor RADIUS (servidor este que se deve manter desligado) mas não introduza já a senha. Corra o comando `who` na consola de R1. O relatório apresentado corresponde ao esperado? Introduza agora a senha solicitada na sessão SSH. Volte a correr o comando `who` na consola de R1. O que mudou? Cancele a sessão SSH (Ctrl+C).
15. Volte a estabelecer a sessão SSH com R1, mas, desta feita, use as credenciais da *local fallback account*. Obteve o mesmo desfecho ou houve diferenças face à última tentativa de acesso? Se registou um comportamento diferente tente justificá-lo com base na documentação oficial.
16. Pela sessão de consola com R1 atualize a lista de autorização `default` acrescentando no final da lista a *keyword* `if-authenticated`. Repita a tentativa de acesso SSH usando as credenciais do utilizador criado em R1. Obteve o mesmo desfecho ou houve diferenças? Com que privilégios ficou o utilizador nessa sessão? Consegue explicar a situação e o impacto da nova *keyword* introduzida na configuração? Termine essa sessão SSH.
17. Atualize, pela sessão de consola, a lista de autorização de R1 acrescentando `local` como último método: `aaa authorization exec default group radius local`. Repita a tentativa de acesso SSH usando as credenciais do utilizador criado em R1. Obteve o mesmo desfecho ou houve diferenças? Com que privilégios ficou o utilizador nessa sessão? Consegue explicar a situação? Termine a sessão SSH.
18. Pela sessão de consola estabelecida elimine o utilizador criado em R1. Recrie-o, mas agora com o privilégio 15 associado (`username luiss privilege 15 secret XPTO`). Repita a tentativa de acesso SSH usando estas credenciais. Obteve o mesmo desfecho ou houve diferenças? Com que privilégios ficou o utilizador nessa sessão? Consegue explicar a situação?
19. Volte a iniciar o serviço RADIUS (`service freeradius start`). Vai testar o serviço de Accounting sobre RADIUS. Tal como sucede com os processos de Autenticação e Autorização, também aqui podemos criar listas de métodos novas ou configurar a lista *default*. Por brevidade da configuração necessária vamos adotar a segunda das estratégias. No modo de configuração de R1 execute o

comando `aaa accounting exec default start-stop group radius`. Termine a sessão SSH que abriu em A1 para R1. Estabeleça nova sessão para que se repita o processo de *Authentication*, *Authorization* e, neste caso, de *Accounting*. Inspeção o nível de privilégios atribuído e termine a sessão. Guarde um *screenshot* do resumo das capturas de todas as PDUs RADIUS envolvidas e outro com os detalhes das novas mensagens relativas ao processo de *Accounting*. Grave as capturas de tráfego realizadas para posterior consulta durante a avaliação.

20. Inicie uma nova captura em AAA-1. No projeto anterior constatou que as *Views (Role Based Access Control - RBAC)* fornecem um mecanismo mais flexível que os privilégios para controlo de permissões. É possível, usando uma abordagem em tudo semelhante à seguida para os privilégios (exercitada nos pontos anteriores), autorizar um utilizador através da atribuição de uma vista (e não um nível de privilégios) a um utilizador corretamente autenticado por RADIUS. Pesquise que padrão de *Cisco-AVPair* permite operacionalizar no IOS esta funcionalidade. Crie uma vista em R1 que permita apenas executar comandos `show`, crie um novo utilizador na base de dados do serviço RADIUS cujo *username* seja igual ao já criado mas que termine em “2” (e.g., `lsantos2`) e afine o respetivo *Cisco-AVPair* de modo que, ao ser bem autenticado, fique associado à vista criada. Estabeleça nova sessão SSH de A1 para R1 com o novo utilizador e consulte a vista ativa assim que entra. Como fica o *prompt* da CLI? Ao utilizador original (`lsantos`) associe no servidor RADIUS a vista raiz (`root`). Não precisa de criar esta vista pois está predefinida no IOS. Estabeleça nova sessão SSH de A1 para R1 com este utilizador e consulte a vista ativa assim que entra. Como fica o *prompt* da CLI? Termine a sessão de consola (`exit`), através da qual estava a configurar o *router*. Reentre na consola com o utilizador original. Consulte a vista em que fica. Provavelmente aparecer-lhe-á a seguinte mensagem “*No view is active ! Currently in Privilege Level Context*”. Consulte o nível de privilégios. Adicione à configuração a seguinte linha: `aaa authorization console`. Volte a terminar a sessão da consola e restabeleça-a com o utilizador original (`lsantos`). Consulte a vista ativa assim que entra. Como fica o *prompt* da CLI? Encontra alguma incongruência entre o *prompt* mostrado nesta sessão e aquele que é mostrado ao mesmo utilizador numa sessão SSH aberta para este mesmo *router*? Inclua *screenshots* das configurações realizadas para o efeito, dos acessos a R1, das *views* reportadas, do resumo das PDUs RADIUS associadas à autenticação/autorização em causa e os detalhes da mensagem *Access-Accept*. Indique ainda a fonte de informação que consultou para descobrir o *Cisco-AVPair*. Termine e grave a(s) captura(s) realizada(s) até aqui para consulta posterior.
21. Inicie uma nova captura em AAA-1 para consulta posterior. Além do serviço RADIUS, a *appliance* GNS3 AAA possui o serviço TACACS+ (*Terminal Access Controller Access Control Server Plus*) ativo. Conforme se recordará das aulas, o TACACS+ começou por ser um protocolo proprietário da Cisco mas entretanto foi aberto à comunidade e até normalizado. No relatório produzido pelo comando `service --status-all` este serviço surge identificado pelo nome `tacacs_plus`. No entanto o ficheiro do *daemon* possui efetivamente outro nome: `/usr/sbin/tac_plus`. É por `tac_plus` que este *software* é conhecido na comunidade Linux. Trata-se de uma implementação *open source* desenvolvida e mantida pela empresa [Shrubbery](#) a partir do código base aberto pela Cisco à comunidade no seu *TACACS+ developer's kit*. Comece por rever as [diferenças](#) entre o serviço RADIUS e o TACACS+. Investigue resumidamente o que oferece ([RFC 8907](#)) e como se [configura](#) em Ubuntu este serviço.
22. Programe R1 de modo que, por omissão, os processos de autenticação, autorização e *accounting* sejam assegurados por TACACS+. Deve começar por criar três utilizadores (“ana”, “bela” e “carla”) no sistema operativo de AAA-1 usando o comando `adduser` (veja Sistemas Operativos I). Pode inspirar-se [neste exemplo](#) para resolver o resto do desafio. Pretende-se que configure o processo de autenticação TACACS+ de modo a serem usados os utilizadores que registou ao sistema operativo de AAA-1. O servidor TACACS+ deve possuir registado no seu ficheiro de configuração o utilizador “admin”. Para maior segurança a sua senha, guardada no ficheiro de configuração, deve ser registada como síntese MD5 (`tac_pwd -p`). Para maior segurança a senha que protege o acesso dos clientes (e.g. R1) ao serviço TACACS+ deve ser gerada com a ferramenta [pwgen](#). Instale esta ferramenta (`apt install -y pwgen`) em AAA-1 ligando, para o efeito, este *container* à [Internet](#). Deve poré No servidor TACACS+ deve autorização programe o servidor para permitir Mostre por *screenshots* as configurações necessárias (em R1 e AAA-1) para que o primeiro utilizador, mencionado no início desta ficha, possa apenas realizar um subconjunto restrito de comandos (definidos por si) autorizados pelo serviço TACACS+. Mostre e explique, em *screenshot* distintos, vários resumos do tráfego TACACS+



Instituto Superior de Engenharia de Coimbra
Departamento de Engenharia Informática e de Sistema

capturado que está associado a cada processo em particular (autenticação, autorização e *accounting*) bem como os detalhes mais relevantes dos pacotes capturados.

Nota: Se houver texto dúbio releia o enunciado. Se as dúvidas persistirem assuma uma interpretação razoável do mesmo e esclareça na resposta à pergunta em causa a interpretação assumida e a razoabilidade da mesma.

Nota: Discuta o enunciado com os colegas e até eventuais respostas. No entanto deve realizar a sua própria resolução, deve realizar todas as experiências descritas, compreender com clareza todas as configurações aplicadas assim como compreender os resultados obtidos nas experiências realizadas.